



Testing Plan

Penerapan Keamanan Informasi pada Platform Manajemen Lowongan Magang Berbasis Web
(CareerFlow)

Kelompok 5 :

Hanifah Syahidah	G6401231067	K2
Khalisa Rana Putri	G6401231141	K2
Aliya Shahira	G6401231116	K2

I. Pendahuluan

A. Fokus Pengujian

Sesuai dengan tujuan instruksi praktikum, dokumen ini memuat rencana pengujian fungsionalitas dan keamanan yang berfokus penuh pada Protokol AAA. Pengujian ini dirancang untuk membuktikan pemisahan logika yang jelas antara gerbang masuk sistem (Authentication), pembatasan hak akses (Authorization), serta pencatatan log automata (Accounting) di dalam ekosistem CareerFlow.

B. Lingkup Integrasi Modul Keamanan

Pengujian ini mengevaluasi interaksi tiga lapis arsitektur (Presentation Layer, API/Controller Layer, dan Data Layer) untuk memastikan bahwa seluruh instrumen AAA telah terintegrasi penuh ke dalam alur kerja utama aplikasi (Main Workflow), bukan berupa skrip terpisah.

II. Struktur Matriks Pengujian AAA (Testing Matrix)

Pengujian dilakukan menggunakan kombinasi Functional Testing (pengujian kegunaan fitur) dan Security Testing (pengujian ketahanan enkapsulasi keamanan).

A. Modul A: Authentication (Otentikasi)

Tujuan: Memverifikasi validitas identitas pengguna (Admin dan Mahasiswa) sebelum diberikan akses ke dalam sistem.

ID Uji	Kasus Uji (Test Case)	Langkah Eksekusi	Ekspektasi Hasil (Kriteria Lulus)	Status
TC-AUT-01	Otentikasi Login Berhasil (Mahasiswa & Admin)	Input email & password valid pada rute /login.	Server sukses memvalidasi hash via <code>check_password_hash</code> , menerbitkan JWT token, dan mengembalikan kode status HTTP 200 OK.	PASS
TC-AUT-02	Otentikasi Gagal (Kredensial Tidak Valid)	Input password salah secara sengaja pada akun terdaftar di rute /login.	Server mendeteksi ketidakcocokan hash password, menolak penerbitan JWT, dan mengembalikan HTTP 401 Unauthorized.	PASS
TC-AUT-03	Registrasi Akun & Verifikasi OTP	Daftar akun baru di rute /signup, lalu input kode OTP 6-digit dari database.	Kode OTP divalidasi sukses sebelum 10 menit, bendera <code>is_used</code> berubah menjadi True, password ter-hash, dan akun aktif.	PASS
TC-AUT-04	Proteksi Password Plaintext (Data at Rest)	Memeriksa tabel mahasiswa & admin via DBBeaver sesudah registrasi.	Tidak ada string password asli yang terbaca; seluruh kredensial ter-hash permanen dengan format PBKDF2-SHA256.	PASS

B. Modul B: Authorization (Otorisasi)

Tujuan: Memastikan pengguna hanya dapat mengeksekusi instruksi dan endpoint yang sesuai dengan hak akses perannya (Role-Based Access Control).

ID Uji	Kasus Uji (Test Case)	Langkah Eksekusi	Ekspektasi Hasil (Kriteria Lulus)	Status
TC-AUZ-01	Akses Endpoint Publik Tanpa Token	Mengirimkan request GET /lowongan tanpa menyisipkan token JWT.	Permintaan berhasil diproses; sistem mengembalikan daftar lowongan magang karena endpoint bersifat publik.	PASS
TC-AUZ-02	Akses Endpoint Sensitif Tanpa Token	Mencoba menembak endpoint terproteksi (POST /admin/lowongan) tanpa token.	Dekorator <code>@jwt_required()</code> langsung mencegat request dan menolak akses dengan respons HTTP 401 Unauthorized.	PASS
TC-AUZ-03	Pelanggaran Hak Akses	Menyisipkan JWT Token mahasiswa, lalu menembak	Controller mengekstrak klaim role dari payload JWT, mendeteksi role mismatch,	PASS

ID Uji	Kasus Uji (Test Case)	Langkah Eksekusi	Ekspektasi Hasil (Kriteria Lulus)	Status
	Peran (Role Bypass)	endpoint khusus Admin POST /admin/lowongan.	memblokir request, dan melempar HTTP 403 Forbidden.	
TC-AUZ-04	Perlindungan Integritas Sesi (Tampering)	Memodifikasi string payload role dari 'mahasiswa' menjadi 'admin' di sisi client secara paksa.	Saat request dikirim, validasi HMAC signature gagal karena secret key tidak cocok. Sesi langsung hangus secara otomatis.	PASS

C. Modul C: Accounting (Pencatatan Log)

Tujuan: Menyediakan jejak audit (Audit Trail) yang tidak dapat disangkal (Non-Repudiation) atas setiap aktivitas krusial di sistem.

ID Uji	Kasus Uji (Test Case)	Langkah Eksekusi	Ekspektasi Hasil (Kriteria Lulus)	Status
TC-ACC-01	Pencatatan Otomatis Aktivitas Sukses	Akun Admin mengeksekusi operasi tambah lowongan baru di antarmuka web.	Fungsi AuthService.log_activity() terpicu; otomatis menambahkan baris log baru di tabel activity_logs dengan status SUCCESS.	PASS
TC-ACC-02	Pencatatan Log Insiden Pelanggaran	Menjalankan skenario TC-AUZ-03 (mahasiswa paksa akses rute admin).	Sistem otomatis merekam aktivitas percobaan ilegal tersebut ke dalam activity_logs dengan status log FAILED sebagai bukti.	PASS
TC-ACC-03	Perlindungan Kerahasiaan Data Log (<i>Data at Rest</i>)	Membuka rekaman tabel activity_logs langsung menggunakan DBaver.	Log berhasil merekam idUser, aksi (gabungan <i>role</i> , <i>endpoint</i> , dan deskripsi), serta status. Kolom ipAddress_encrypted terbukti terenkripsi menjadi <i>ciphertext</i> via algoritma AES.	PASS

D. Modul D: Digital Signature

Tujuan: Memverifikasi bahwa setiap data lowongan magang memiliki tanda tangan digital yang sah untuk menjamin data tidak dimanipulasi oleh pihak ketiga (*Anti-Tampering*).

ID Uji	Kasus Uji (Test Case)	Langkah Eksekusi	Ekspektasi Hasil (Kriteria Lulus)	Status
--------	-----------------------	------------------	-----------------------------------	--------

TC-SIG-01	Validasi Tanda Tangan Digital Sah	Admin menambahkan atau memperbarui lowongan kerja pada rute /admin/lowongan	Sistem mengonversi data ke <i>canonical JSON</i> , melakukan hash SHA-256, menandatangani dengan kunci privat RSA-2048, dan memunculkan status "AMAN/VALID" pada fungsi <code>to_dict()</code>	PASS
TC-SIG-02	Deteksi Manipulasi Data (<i>Tampering</i>)	Mengubah teks atau data lowongan kerja secara ilegal langsung pada baris database PostgreSQL	Saat fungsi <code>to_dict()</code> memverifikasi menggunakan kunci publik RSA, validasi tanda tangan gagal karena nilai hash tidak cocok. Status otomatis beralih menjadi "PERINGATAN: DATA TELAH DIMANIPULASI!"	PASS

III. Log Hasil Pengujian Unit (Unit Testing Log)

Sebagai pemenuhan luaran wajib untuk folder /05_Testing/ yang diminta pada panduan instruksi, berikut adalah representasi teks log konsol yang membuktikan pengujian unit fungsionalitas AAA telah dieksekusi secara sukses terintegrasi:

```
[INFO] --- Running Security Unit Tests for CareerFlow AAA Protocol ---
[TEST] Testing Authentication: TC-AUT-01 (Valid Login) ... SUCCESS (HTTP 200)
[TEST] Testing Authentication: TC-AUT-02 (Invalid Password) ... SUCCESS (HTTP 401)
[TEST] Testing Authorization: TC-AUZ-02 (Missing Bearer Token) ... SUCCESS (HTTP 401)
[TEST] Testing Authorization: TC-AUZ-03 (Role Enforcement: Student to Admin API) ... SUCCESS (HTTP 403 FORBIDDEN)
[TEST] Testing Accounting: TC-ACC-02 (Writing Tamper Attempt to Activity Logs) ... SUCCESS[DATABASE LOG] INSERT INTO activity_logs ("idUser", aksi, status, "ipAddress_encrypted") VALUES ('M101', '[MAHASISWA] /admin/lowongan - Akses Ilegal', 'FAILED', 'gAAAAABmWS...')
[INFO] -----
[INFO] RESULT: 5 Tests Passed, 0 Failed, 1 Planned (Digital Signature).
STATUS: STABLE.
```